

Incident Response Reference Guide

AI Agent for Cybersecurity Incident Response | u2u Internship Project, 2026

1. Why we made this document

One of the first things we ran into while building the AI agent was the question of where it gets its knowledge from. You can't train a model from scratch for an internship project, and hardcoding every possible response into the code would be a nightmare to maintain. So we decided to use a RAG setup — the agent searches through documents like this one at runtime and uses what it finds to answer questions.

This guide is the agent's reference handbook for incident response. When someone reports a security incident, the agent looks through this document, cross-references the playbooks and CVE data we collected, and puts together a response.

2. Severity levels we use

We settled on four levels after looking at how most real SOC teams classify things:

Level	Meaning	Response time	Example
Critical	Active breach or major system down	Under 1 hour	Ransomware, zero-day
High	Serious risk, likely data exposure soon	Under 4 hours	Phishing, DDoS, SQLi
Medium	Contained for now but needs attention	Under 24 hours	Failed brute force
Low	Minor, mostly just worth logging	Under 72 hours	Port scan, 1 failed login

3. The response process

This is the general flow we follow for any incident. The AI agent uses this structure to make sure nothing gets skipped.

3.1 Preparation

Everything before an incident — setting up logging, writing playbooks, testing backups. If this is skipped, everything else falls apart when something real happens.

3.2 Detection

Something gets flagged by a tool or a person. Confirm if it's real or a false alarm, and if real, what type and how bad so far.

3.3 Containment

Stop it from spreading. Take the machine offline, disable the account, block the IP. Don't try to fix things yet, just stop the damage.

3.4 Eradication

Remove the actual threat. Delete the malware, patch the vulnerability, revoke stolen credentials. Make sure no backdoor is left.

3.5 Recovery

Bring things back online carefully, restore from backups if needed, and watch closely in case the attacker tries coming back.

3.6 Post-Incident Review

Figure out what happened and why. Update the playbooks with anything that didn't work. This is what actually makes security improve over time.

4. Attack types covered in our playbooks

These are the six attack types we focused on — most common in real incident logs and well documented enough to build reliable playbooks around.

Attack type	What it is	First thing to do
Phishing	Fake email tricks user into giving credentials or clicking malware	Block sender, reset the user's password immediately
Ransomware	Malware encrypts files and demands payment	Pull machine off network right away — do not pay
DDoS	Flood of traffic makes a service unavailable	Enable rate limiting, contact ISP to block upstream
SQL Injection	Attacker manipulates the database through a web input	Block IP at WAF, take app offline, check DB logs
Unauthorized Access	Someone logged in who shouldn't have	Kill session, disable account, check what they accessed
Insider Threat	Employee or contractor abusing their own access	Disable account quietly, then preserve logs before deletion

5. How the agent actually uses this

When an analyst submits an incident, here's roughly what happens:

1. Analyst describes what they're seeing — e.g. 'user got a suspicious email and clicked a link'
2. Agent converts that into a search query and looks through this PDF for relevant sections
3. It also pulls the matching playbook from playbooks.json and any related CVE from cve_data.json
4. Then checks incidents_db for similar past incidents
5. Finally puts together a clear response — what to do, in what order, and who handles it

The reason we keep this as a separate PDF rather than embedding everything in the code is simple — it's way easier to update. New attack type comes up, we add a section here and the agent picks it up automatically next time it runs.